ZCAS UNIVERSITY

CIT 3381 ORGANIZATIONAL AND SOCIETAL SECURITY FINAL EXAMINATIONS

FINAL EXAMINATIONS

FRIDAY, 5TH JUNE, 2026

TIME: 09:00 – 12:00 HOURS

TIME ALLOWED: THREE (03) HOURS

INSTRUCTIONS TO CANDIDATES:

1. **SECTION A:** This section is **compulsory** with **ONE (01)** Question and carries **40 marks.**
2. **SECTION B:** Attempt **any THREE (03)** questions from this section. Each question carries **20 marks**.
3. This examination paper carries a total of **100 marks.**
4. Time allowed: **THREE (03) Hours plus FIVE (05) minutes to read through the paper.**
5. **DO NOT** turn this page **until** you are told to do so.

SECTION A

QUESTION ONE (COMPULSORY – 40 MARKS)

Securing the Enterprise: The ZamNet Corporation Data Breach

ZamNet Corporation, a major Zambian ISP serving 500,000 customers across six African countries, suffered a data breach in early 2025 in which 120,000 customer records were stolen. Investigations revealed that a disgruntled insider had sold access credentials to attackers; there were no role-based access controls, no Information Security Policy, and no SIEM system to detect the intrusion. The breach went undetected for 47 days.

Physical server room access relied on paper sign-in sheets rather than biometric controls, and staff had received no security awareness training in three years. Customers subsequently reported identity theft, a consumer rights body filed a complaint with ZICTA under the Cyber Security and Cyber Crimes Act (2021), and the company faced regulatory investigations in two additional countries. In response, a new CISO was appointed to develop an Enterprise Security Architecture and Business Continuity Plan.

Required:

(a) Using the case, explain why conducting a Risk assessment is critical in organisational security, and identify **four security failures** at ZamNet. For each, recommend an appropriate control.

(10 marks)

(b) Distinguish between **malicious** and **negligent insider threats**. Using evidence from the case, propose a mitigation strategy for each type. *(10 marks)*

(c) Define **Risk Assessment** in the context of information security. Describe the key steps involved in conducting a risk assessment and explain how each step could be applied to the case study of **ZamNet Corporation**. *(10 marks)*

(d) In the context of information security, define the term **compliance**. Explain why it is important for organizations to comply with established security standards and regulations. In your answer, discuss the benefits of compliance and provide examples of **at least two security standards or frameworks** that organizations are required or encouraged to follow. *(10 marks)*

(Total: 40 Marks)

SECTION B

ATTEMPT ANY THREE (03) QUESTIONS

QUESTION TWO

(a) Define Risk Management and distinguish between Traditional Risk Management and Enterprise Risk Management (ERM), giving two key differences.

(6 marks)

(b) Using a ransomware attack as your scenario, apply any three (3) of the following techniques: **Avoidance, Retention, Loss Prevention and Reduction, Transfer**.

(6 marks)

(c) Explain **Risk Appetite** and **Risk Tolerance** using the speed-limit analogy, and describe how an organization applies them when setting its security policy.

(8 marks)

(Total: 20 marks)

QUESTION THREE

Many organizations fail to identify risks before they materialize. Research shows that structured, proactive risk identification techniques significantly reduce the frequency and severity of security incidents.

(a) Compare **Brainstorming** and the **Nominal Group Technique (NGT)** as risk identification methods. Give one advantage and one limitation of each.

(6 marks)

(b) Explain how a **SWOT Analysis** can be used for cybersecurity risk identification. Using a fictional Zambian e-commerce company, identify two threats and two weaknesses relevant to its information security posture.

(6marks)

(c) Describe the **Affinity Diagram** technique and explain how it helps an organization categorize and prioritize identified risks.

(8 marks)

Total: 20 Marks)

QUESTION FOUR

Content Under Siege, a case of ZedStream Media Ltd

ZedStream Media Ltd, a Zambian online platform distributing movies, music, and educational videos, discovered that over 35% of its premium content had been pirated within six months of release. An investigation found no Digital Rights Management (DRM) system, no content encryption, and no digital watermarking in place.

(a) Define **Digital Rights Management (DRM)** and state four reasons why it is critical for ZedStream. *(6 marks)*

(b) Explain how **encryption** prevents unauthorised access to digital media. Distinguish between **symmetric** and **asymmetric encryption** and recommend the most suitable approach for ZedStream's streaming service, with justification.

(8 marks)

(c) Define **digital watermarking** and distinguish between **visible** and **invisible watermarks**. Explain how watermarking could help ZedStream identify the source of pirated content.

(6 marks)

(Total: 20 Marks)

QUESTION FIVE

Governing the Ungoverned a Case of Kafue Micro-Finance Bank

Following two data breaches in 2024, an audit of Kafue Micro-Finance Bank (KMFB) found no cybersecurity governance program, no Information Security Policy, no multi-factor authentication, no secure data transmission channels, and no incident response procedures. The bank had also failed to comply with Bank of Zambia cybersecurity directives.

(a) Define **Cybersecurity Governance** and explain its significance. Using the case, identify Four **governance failures** at KMFB and describe the consequences of each.

(8marks)

(b) Describe the **six steps** for implementing a Cybersecurity Governance Program and show how each step applies specifically to KMFB.

(6 marks)

(c) Explain the role of an **Information Security Policy** in an organization. Identify and describe **three types** of policies KMFB should develop, stating the key components of each.

(6 marks)

(Total: 20 Marks)